

The Agentic AI Procurement Playbook

Yesterday's playbook was the regulator's clock. Today is the mirror image: the **buyer's** side. Governance has stopped being an internal hygiene project and become a **contract line item** — and the RFP is where it is caught or missed. The 2024-era AI RFP was a software questionnaire with an “AI section” bolted on; it asked about integrations, certs and price. It did not ask the questions that decide whether the platform survives your next audit cycle, your next regulator review, or your next silent model upgrade. This issue is the new checklist: the buyer questions that matter, the **build-vs-buy** decision for the control plane, the shift from **per-seat to per-outcome** pricing, and why “*show me your audit trail*” is the single most clarifying question you can put to any agentic AI vendor in 2026.

30 questions in the 2026 agentic-AI RFP, across 8 categories (Kognitos template)	19% of orgs have an agentic-AI governance + monitoring platform (Hackett 2026 Index)	21% → 15% per-seat share of SaaS in 12 months as agents break the seat (Gartner)	\$15–\$99 per user/mo for a control plane: Agent 365 standalone → M365 E7 Frontier
--	--	--	--

1 · Governance is now a line item — and the RFP is where it's caught

Three things changed in 2025–26 that make the old RFP inadequate. **First, audit trails became a procurement requirement.** COSO's February 2026 guidance on internal control over generative AI requires that monitoring capture prompts, inputs, outputs, model and config versions, and evidence of human review sufficient to *reconstruct* what the AI acted on; PCAOB AS 2201 (expanded benchmarking effective Dec 15, 2026) conditions any reliance on an automated control on the model's decision logic *not having changed*. **Second, the EU AI Act moved from theory to enforcement** (Day 81): Articles 11, 12, 13, 14 and 86 create vendor obligations the **buyer inherits** if the contract is silent. **Third, platforms diverged architecturally** — deterministic (same input, same output, inspectable rules) versus probabilistic (output varies with model state). Yet only **19%** of organisations run a governance + monitoring platform and just 24% have defined KPIs. The new artefact a buyer asks for is the **AIBOM** (AI Bill of Materials), delivered at deployment and on every material change. One question separates a 2026-ready vendor from a 2022 one: *show me, for a decision you made six months ago, the exact rule applied and who reviewed it.*

***The reframe:** you are not buying features, you are buying evidence you can hand a regulator and an auditor. A brilliant demo on a platform that can't reconstruct a decision is a liability you'll inherit at the next audit cycle. Score governance **before** you score capability.*

2 · The buyer's checklist — the six questions that predict regret

A full RFP runs to 30 questions across eight categories, but six carry most of the signal. Each maps cleanly to a governance primitive this series has built over 80 days — so the checklist below is also a quick test of whether a vendor has actually done the work or is selling a 2022 product with an AI label.

RFP question	What a good answer looks like	Red flag
Audit-trail completeness — what's in the log for each decision?	The 12-field schema: NTP timestamp, decision ID, authenticated human identity, AI system + version, model + version , inputs with source, the specific rule applied , plain-language reasoning, output, downstream action, human-review event, tamper-evident proof.	“We log the confidence score.” A confidence score is not an explanation.

RFP question	What a good answer looks like	Red flag
Model version pinning — what happens when the provider upgrades the model?	Versions pinned per workflow; upgrades are explicit, change-controlled, regression-tested events.	"We always use the latest model." A silent upgrade reopens every AS 2201 effectiveness conclusion.
Tiered human oversight (HITL) — is oversight risk-weighted?	Low-risk auto-approve + sampling audit; medium-risk async review; high-risk synchronous block. Reviewer sees the rule, the inputs and why it escalated.	"We support human-in-the-loop" with no tiering = bottleneck + rubber-stamp theatre.
Agent identity — how is each agent identified and scoped?	Per-agent identity (SPIFFE/SVID or Entra), least-privilege scopes, deprovisioning + periodic access reviews; trail captures both agent and the human who triggered it.	"Agents inherit user permissions" with no agent-level audit trail.
Kill switch + incident SLA — can you stop it, and when are we told?	<1s tiered stop (T1–T4) and a contractual 24–72h incident-notification SLA.	"Logs are stored securely" / no stop control / no notification clause in the contract.
Exit portability — what do we keep if we leave?	Export of data, workflow logic AND audit history , retained through the regulatory floor (6 mo EU high-risk, 6–7 yr SOX/HIPAA).	"You can export your data." Logic and audit history are separate — most contracts ignore them.

3 · Build vs buy — the control-plane decision comes first

The first procurement decision is not *which agent* — it is **which control plane** registers, identifies, governs and audits every agent you run. Get this right and the buyer's checklist above is satisfied by construction. Four paths, chosen by your existing identity backbone and data-residency needs, not by demo dazzle.

Control plane	What you get	Best when...
Microsoft Agent 365 (GA May 1, 2026; \$15/user or M365 E7 \$99 Frontier)	Entra identity per agent, Purview labels, Defender runtime governance, Intune for local agents, multicloud registry sync with AWS Bedrock + Google Gemini Enterprise (preview). KPMG rolled it to 276,000 people.	You are an M365 / Entra shop and want one registry + policy + security plane.
Salesforce Agentforce (per-conversation / Flex Credits)	Agent execution platform inside the Salesforce world; CRM data is the ground truth; self-healing workflows + A2A/MCP native.	High-volume customer-facing automation grounded in CRM data.
Anthropic Claude (Cowork + Code + Managed Agents)	Open Agent Skills standard, MCP tunnels to internal servers, self-hosted sandboxes; cross-domain value layer over whatever control plane you pick.	You want a portable skills/value layer and the open-protocol ecosystem.
Self-host / open (e.g. WSO2 Agent Manager, Apache 2.0; SPIFFE/SPIRE + OTEL→WORM)	You own the registry, the identity issuance and the governance evidence end-to-end; data never leaves your boundary.	Data residency, sovereignty or regulated workloads make "you own the evidence" non-negotiable.

Decision rule: buy the control plane that matches your identity backbone, layer a regulated tier where residency demands it, and build only the proprietary skills and agents that touch your differentiated data. Score every option on the five lenses from the Buyer's Guide (Day 59): control plane, skills ecosystem, governance evidence, distribution, pricing-per-outcome.

4 · Pricing — per-seat is dying; price for outcomes you can audit

When one agent does the work of a team, paying “per seat” stops making sense. Per-seat collapsed from **21% to 15%** of SaaS in twelve months; **hybrid** (a base subscription with usage and/or outcome components) is now the dominant model at ~41–43% adoption, and Gartner expects **≥40% of enterprise SaaS spend** to be usage-, agent- or outcome-based by 2030. The catch is the one this whole issue keeps returning to: **outcome pricing only transfers risk to the vendor if the outcome is tightly defined AND auditable**. The same audit trail you demanded in Section 2 is exactly what makes a “qualified lead” or “resolved ticket” billable without a dispute. Demand a shared, logged definition of the billable outcome — or you will pay for no-shows.

Pricing model	2026 examples	Buyer's watch-out
Per-outcome	Fin ~\$0.99 per resolved outcome (no platform fee); HubSpot \$0.50 per resolved conversation (Apr 2026).	Insist the “outcome” is defined + logged in the audit trail, or disputes follow.
Consumption / per-action	Agentforce ~\$2/conversation + Flex Credits; control-plane fee + inference on top.	Model the fully-loaded cost; a cheap per-action rate hides inference + platform fees.
Hybrid (base + usage/outcome)	Dominant model (~41–43%); enterprises lead with subscription, layer usage underneath.	Predictable, but get the usage caps and overage rates in writing.

Put it in the contract, not the deck. Five protections are now standard: model-version pinning (no silent upgrades), audit-trail completeness (the 12-field schema), a 24–72h incident-notification SLA, AIBOM delivery on every material change, and data + logic + audit portability on termination. If the vendor can't point to the clause, the commitment doesn't exist.

5 · Viral app spotlight — MLflow 3.x, the open governance-evidence layer

On a day about “show me your audit trail,” the app worth knowing is the one that **produces** the trail. **MLflow 3.x** has become the most widely deployed open-source AI engineering platform and — the standout in the June 2026 agent-observability wave — the only fully open-source stack that covers **tracing, evaluation, prompt management, governance and an AI gateway in one place, with no enterprise paywalls**. It is built on an **OpenTelemetry-native** layer, so you emit gen_ai traces once and route them to any backend without re-instrumenting. For a buyer that is the clean answer to “how do I generate Annex IV / 12-field audit evidence without locking into a vendor?” — emit the trace, keep the WORM trail *you* own. It is the procurement-grade governance-evidence layer, in open source. (OpenClaw still tops the raw OSS star charts at 210K+ as the local-first foil — viral, but it ships with no kill switch, no audit trail and no scoped identity: the exact anti-pattern this playbook is built to screen out.)

OTEL-native emit gen_ai traces once, route to any backend, no re-instrumentation	5-in-1 tracing + eval + prompt + governance + gateway in one open platform	\$0 paywall fully open source — the buyer's answer to control-plane lock-in
--	--	---

Practical takeaways

1. Make “show me your audit trail” your first RFP question.

Score vendors on the 12-field log, model-version pinning, tiered HITL and tamper-evidence **before** you score features. A great demo on an un-auditable platform fails your next regulator and auditor review — and the obligation lands on you, the deployer.

2. Buy the control plane; build only what's differentiated.

Pick the registry / identity / governance plane that matches your identity backbone (Agent 365 for M365/Entra, Agentforce for CRM-grounded work, Claude/Cowork as the value layer, WSO2 or self-host for residency). Layer a regulated tier where you must; build only the proprietary skills that touch your unique data.

3. Price for outcomes — but make the outcome auditable, and put it in the contract.

Per-seat is structurally dead; move to hybrid/outcome pricing and insist the billable outcome is defined and logged in the same audit trail. Get model-pinning, audit completeness, a 24–72h incident SLA, AIBOM delivery and exit portability into the contract, not the marketing deck.

Tomorrow (Day 83): *The Agentic AI Operating Model & Agent FinOps — what happens after you sign. Running, costing and scaling the fleet you just bought: model-routing economics, cost- and quality-SLOs at fleet scale, the Agent SRE + CFO view, and how the audit trail you procured becomes your live cost-and-control dashboard.*